WALFIA · SECURITY BRIEF

Scorr Security

Overview for Organizations

How Scorr protects your company data, people, and sessions — written so you can share this with leadership, IT, and compliance.

Platform: https://scorr.walfia.ai

Document: October 19, 2026

Product: Desktop / apps 1.3.44+

Contact: info@walfia.ai

Audience: Company admins · IT · Security reviewers

Multi-tenant · MFA · RLS · 1-hour sessions · Encrypted transport

Table of Contents

1. Executive summary
2. Security principles
3. Multi-tenant data isolation
4. Authentication & passwords
5. Multi-factor authentication (MFA)
6. Session security & absolute timeout
7. Role-based access control
8. Database & API protection (RLS)
9. Company onboarding controls
10. Attendance, location & device tokens
11. Demo sandbox isolation
12. Account recovery & deletion
13. Desktop & mobile apps
14. Auto updates & distribution
15. What we do not claim
16. Security checklist for your organization
17. Contact & further documents

© Walfia · Scorr Security

1. Executive summary

Scorr is a multi-company performance and attendance platform available on the web, Windows, Linux, Android, and iPhone. Every organization runs as a private tenant: your people, KPIs, attendance, rewards, daily reports, and location/Wi-Fi attendance signals are separated from every other company on the same platform.

Security is built into the product — not bolted on later. Access requires a verified login, mandatory authenticator MFA for production accounts, absolute 1-hour sessions, configurable trusted devices, and database policies that enforce who can read or write each record.

In one sentence

> Scorr is designed so that only authenticated users in your company, with the correct role, can see your data — over encrypted HTTPS — with MFA, trusted devices (default 7 days, Admin up to 30), rate limits, 1-hour sessions, and company-scoped storage.

Who this document is for

- Company leadership evaluating Scorr for rollout.
- IT / security teams reviewing architecture and controls.
- HR and Admin owners who must explain “how secure is it?” to stakeholders.

2. Security principles

- Least privilege — each role sees only what the role needs (Admin, HR, Manager, Employee).
- Tenant isolation — company_id scopes data; Company A cannot query Company B.
- Defense in depth — browser/app ⁉ HTTPS ⁉ Auth ⁉ role checks ⁉ Row Level S
- Verify identity — password + MFA (TOTP) for production accounts; backup codes and email recovery when devices are lost.
- Minimize sensitive data — location and Wi-Fi signals are used only inside the attendance window (1 hour before shift start until shift end) for automatic or manual office attendance; not sold or shared across tenants.
- Secure device secrets — auto-attendance device tokens live in Android Keystore, iOS Keychain, or Electron safeStorage — not in plain localStorage.
- Audit & recovery — login attempt recording, admin authenticator reset, account deletion with owner safeguards.

3. Multi-tenant data isolation

Scorr hosts many organizations on one platform. Isolation is enforced in application logic and in the database.

3.1 How tenants are separated

- Every user and business record is tied to a company_id.
- Queries and RPC functions resolve the current company from the signed-in user.
- Lists (people, KPIs, attendance, reports, rewards) are filtered to that company.
- Platform-owner tools (/platform) approve companies; they are not a “super user” inside your day-to-day employee data for other orgs beyond platform operations.

3.2 What this means for you

- Your competitors on Scorr cannot open your dashboards or export your files.
- Managers only see their allowed team scope; employees only see their own records.
- HR and Admin work inside your organization boundary.

Isolation depends on correct role assignment. Train admins to assign HR / Manager / Employee carefully and keep “Reports to” accurate.

4. Authentication & passwords

4.1 Identity provider

Scorr uses Supabase Auth for sign-in. Passwords are hashed by the auth service — they are not stored as readable plain text in your company tables.

4.2 Password rules & reset

- Minimum password length: 6 characters (enforced at registration and change).
- Forgot password: rate-limited email of a temporary password (about 15 minutes cool-down when limited).
- Change password: verified through a secured server function so MFA sessions remain consistent.

4.3 Login abuse protection

- Failed sign-in attempts are recorded.
- Rate limiting blocks rapid password guessing (“Too many sign-in attempts. Wait 15 minutes…”).
- Forgot-password requests are also rate-limited.
- Generic error messages avoid revealing whether an email exists when that would help attackers.

Control	Purpose
Hashed passwords	Credential theft from DB does not expose clear passwords.
Login rate limit	Slows brute-force attacks.
Forgot-password limit	Stops reset email flooding.
HTTPS only	Credentials and tokens travel encrypted in transit.

5. Multi-factor authentication (MFA)

Production Admin, HR, Manager, and Employee accounts must enroll authenticator MFA. Demo sandbox accounts skip MFA by design.

5.1 What users enroll

- TOTP apps: Google Authenticator or Microsoft Authenticator (industry-standard time-based codes).
- After enrollment, users receive 10 one-time backup codes (format like ABCD-EFGH).
- Backup codes are burned after use — store them offline.

5.2 Daily login

- Password (first factor) + authenticator code (second factor), or
- Password + one unused backup code if the phone is unavailable.
- Optional: “Trust this device” after a successful code — skip MFA on that device for a limited time.
- Default trust length: 7 days. Company Admin (Settings !’ Security) can set s

ask, 1, 7, 14, or up to 30 days.

- Trusted-device tokens are hashed server-side, rotated on each use, and never slide past the original expiry.
- Web: HttpOnly Secure SameSite=Strict cookie. Apps: Keystore / Keychain / desktop safeStorage.
- Auto-revoked on password change/reset, admin authenticator reset, MFA re-enrollment, or user deletion.
- Platform owners always ask for a code (no trust). Admins can set Always ask for staff or privileged roles.

5.3 Lost device recovery

- Email OTP recovery path (time-limited) to verify the user, then re-enroll a new authenticator.
- Optional recovery email under Settings !’ Account security.
- Company Admin can Reset authenticator from People for a locked-out teammate (privileged action).

MFA raises the bar significantly: a stolen password alone is not enough to open the dashboard for production accounts.

© Walfia · Scorr Security

6. Session security & absolute timeout

6.1 Session model

- After successful auth + MFA (or a valid trusted-device token), Scorr issues a session for the browser or native app.
- Sessions are bound to the authenticated user; API calls use that identity (auth.uid()).

6.2 Absolute 1-hour logout

- Sessions last one hour from sign-in on web, Capacitor (Android/iOS), and Electron desktop — not a sliding idle timer.
- After one hour the portal signs out and returns the user to Sign In with a clear “session expired” message.
- JWT refresh may continue inside that hour; past one hour the client forces logout.
- Remember-me credentials and attendance device tokens are not cleared by session expiry (separate secure storage).

6.3 Practical guidance for organizations

- On shared PCs use Sign out & forget this device so the next person must enter MFA.
- Do not share login credentials between people — create one account per person.
- Revoke access promptly in People when someone leaves the company.

© Walfia · Scorr Security

7. Role-based access control

Scorr enforces four company roles. The UI and server both respect the role.

Role	Security-relevant access
Admin	Full company configuration: people, departments, offices, tasks, rewards, attendance oversight, exports, branding, MFA trust policy. Approves manager/HR leave; receives HR/manager daily-report alerts.
HR	Company operations console; must report to a company admin. Own attendance + daily report go to admin. Cannot bypass tenant isolation.
Manager	Department/team scope: assign KPIs, approve employee leave/gifts, own attendance and daily report.
Employee	Own KPIs, attendance, leave requests, daily report, gift redeem — no company-wide admin tools.

Why this matters

- A compromised employee password (even with MFA bypass attempts) still cannot manage the whole org.
- Managers cannot see unrelated departments outside their allowed scope.
- Privilege changes are controlled by Admin in People.

8. Database & API protection (RLS)

8.1 Row Level Security

PostgreSQL Row Level Security (RLS) is enabled on core tables (users, KPIs, notifications, attendance-related data, and other business tables). Policies typically allow:

- A user to read/update their own rows.
- A manager to access their team where is_manager_of applies.
- Admin/HR (company privileged roles) to manage within the company.

8.2 Security-definer functions

- Sensitive operations run through controlled SQL functions (SECURITY DEFINER) that still check auth.uid(), role, and company.
- Examples: attendance geo/Wi-Fi processing, leave submit/review, daily report submit, user updates, office assignment.
- Clients cannot freely rewrite another company's tables through the public API.

8.3 Edge functions for privileged actions

- Password change, forgot password, MFA recovery, authenticator reset, trusted-device policy, account deletion, and similar flows run as server-side edge functions.
- These keep privileged Auth Admin operations off the browser.

Even if someone tampers with the UI, the database policies and RPCs are the source of truth for authorization.

© Walfia · Scorr Security

9. Company onboarding controls

9.1 Registration is not instant full access

- Register Company collects account + company details.
- Email verification OTP (6 digits) confirms the registrant owns the inbox.
- Status becomes awaiting platform approval — dashboard stays closed until approved.
- Walfia platform owner reviews at /platform (Approve / Reject / Pause).
- Trial starts on approval — reduces fake or abusive signups.

9.2 Ongoing company status

- Paused / suspended / rejected companies cannot use the product normally.
- Contact info@walfia.ai for account status issues.

10. Attendance, location & device tokens

10.1 What is collected

- Automatic attendance (one-time device enrollment, non-expiring device token in secure storage): office Wi-Fi match (SSID and/or BSSID for any saved network on an assigned location) and/or GPS inside assigned office radius.
- Policy wifi_then_radius: saved office Wi-Fi alone is enough to check in (no GPS required). Otherwise GPS inside radius is required. Public/unsaved Wi-Fi never counts.
- Window W = [shift start − 60 minutes, shift end] in the shift's IANA time zor auto attendance. This does not extend one hour after shift end.
- Manual Clock in/out uses the same window. Early clock-out can be from any place before shift end; open sessions close at shift end.
- After manual Clock Out, clients wait about 30 seconds before auto re-check-in (Android parity on desktop).
- Platforms: Android, iOS, Windows, and Linux installed apps support Enable automatic check-in. Normal browsers show setup/download only.
- Desktop requires the real Scorr Desktop binary (window title Scorr Desktop x.y.z) — not Chrome “Install app” / PWA.
- Remote staff may be marked by supervisors without GPS.

10.2 How it is protected

- Location APIs require a secure context (HTTPS) — e.g. https://scorr.walfia.ai.
- Attendance records are company-scoped; other tenants cannot read them.
- Device tokens are stored in Keystore / Keychain / Electron safeStorage.
- Scorr does not sell location data and does not expose it to other organizations.
- Background GPS/Wi-Fi on enrolled devices runs only during W — not 24/7 marketing tracking.
- Prominent disclosure + Always location on phones; setup wizard explains permissions before enrollment. Desktop uses tray / start at login.

10.3 Organizational recommendations

- Publish an internal policy: MFA required; trusted devices default 7 days (configurable up to 30 or Always ask); auto attendance uses background location after setup.
- Ask staff to complete Enable automatic check-in on the installed app and grant Always / background location (phones) or tray permissions (desktop).
- Assign office zones and save only legitimate office Wi-Fi networks.
- Use Remote/Hybrid work modes when GPS/Wi-Fi attendance is not appropriate.

© Walfia · Scorr Security

11. Demo sandbox isolation

Public demo accounts (?demo=1) exist for product trials. They are isolated from production companies.

- Demo users are flagged is_demo.
- enforce_demo_isolation prevents demo sessions from touching real company users.
- Demo admins cannot provision real production staff.
- MFA is skipped only for demo — never for real company accounts.

Always evaluate security using a real approved company account, not the public demo personas.

12. Account recovery & deletion

12.1 Recovery

- Forgot password ?’ rate-limited temporary password email.
- MFA email recovery + backup codes + admin authenticator reset.
- Settings ?’ Account security: regenerate backup codes, set recovery email, m

Forget all), view recovery-related activity.

12.2 Account deletion

- Self-serve: Settings ?’ Delete my account (type DELETE + password).
- Help page: https://scorr.walfia.ai/delete-account
- Company owners with remaining members must transfer ownership or confirm full company deletion — prevents accidental wipe of a live org.
- Email info@walfia.ai for assisted requests (handled within stated support window).

13. Desktop & mobile apps

Scorr offers the same authenticated experience on Windows and Linux desktop installers, Android APK, iPhone Home Screen / native shell, and the website. All clients talk to the same backend over HTTPS with the same MFA and company isolation. Current product line: 1.3.44+.

13.1 Shared security properties

- Same Sign In, MFA (TOTP), trusted devices, backup codes, roles, and tenant isolation as the website.
- Store/download CTAs are hidden inside an already-installed app shell.
- Location permission is requested for office attendance — on phones, prefer Always / background so auto check-in works without opening the dashboard.
- Absolute 1-hour session timeout and privileged MFA gates apply on every client.
- Apps load https://scorr.walfia.ai/?app=1 so most product updates ship with the website; native changes use in-app / auto-updaters.

13.2 Windows desktop (Scorr-Setup.exe)

- Official installer from GitHub Releases (e.g. desktop-v1.3.44) linked from https://scorr.walfia.ai/#download-windows.
- Installs permanently with Start Menu and Desktop shortcuts — window title Scorr Desktop x.y.z.
- electron-updater checks on launch and around 5 AM; Check for updates downloads/installs in the background.
- Content-Type fix: Electron forces correct MIME types for CSS/JS assets. Some Windows proxies/AV return text/plain, which Chromium refuses — that caused blank screens after login on older builds. Current Desktop 1.3.44+ overrides those headers.
- If Windows SmartScreen warns, verify the download came from scorr.walfia.ai / the official GitHub Release before continuing.

13.3 Linux desktop (.deb + AppImage)

- Official packages from the same GitHub Release: Scorr.deb and Scorr.AppImage.
- Prefer AppImage for silent electron-updater auto-update. .deb shows an in-app download banner when newer.
- Same Electron shell, safeStorage device tokens, and backend auth as Windows.

13.4 Android & iOS

- Android APK from https://scorr.walfia.ai/downloads/scorr.apk — release-signed with in-app update when versionCode advances (background download, then OS Install sheet — cannot be fully silent).
- iOS: Safari Add to Home Screen (?app=1); App Store when available. Native Capacitor builds support Enable automatic check-in like Android.
- Install APKs and desktop packages only from scorr.walfia.ai and the linked GitHub Release. Manifest: /downloads/version.json.

> Do not install Scorr Setup.exe, .deb, AppImage, or APKs from unknown websites. Official source: scorr.walfia.ai (and the linked GitHub Release). Large packages are hosted on GitHub Releases, not as Vercel binary hosting.

14. Auto updates & distribution

14.1 Web / Electron UI

- Clients poll /build-meta.json and hard-refresh when webBuildId advances — silent, no “Updating…” banner.

14.2 Desktop binaries

- NSIS (Windows) and AppImage (Linux): electron-updater on launch + ~5 AM; Check for updates downloads/installs in background.
- .deb: download banner / prefer AppImage for silent updates.
- Updater metadata under /downloads/desktop/; binary assets on GitHub Releases.

14.3 Mobile

- Android: background download then system Install prompt.
- iOS Home Screen: same as web hard refresh; native IPA via TestFlight / App Store when published.

15. What we do not claim

Transparency builds trust. This brief describes product and platform controls as implemented in Scorr. It is not a substitute for your own legal, privacy, or compliance review.

- This document does not assert a specific third-party certification (for example SOC 2 or ISO 27001) unless Walfia has separately provided that certificate to you.
- Security is shared: strong MFA and access hygiene on your side remain essential.
- No system can guarantee zero risk; Scorr reduces risk through layered controls.
- For contracts, DPAs, or region-specific residency requirements, contact info@walfia.ai.

16. Security checklist for your organization

Before go-live

- Approve only real company admins; complete MFA enrollment for every production user.
- Set MFA trust policy (default 7 days; optionally up to 30 days or Always ask for staff vs admin/HR).
- Create departments; assign Managers and Employees with correct Reports to lines.
- Set Work location (Office / Remote / Hybrid) per person.
- Configure office locations and save legitimate office Wi-Fi networks; tell staff auto attendance uses background location after Enable automatic check-in.
- Train staff: never share passwords; store backup codes offline; use real Scorr Desktop for desktop auto attendance.

Ongoing

- Offboard leavers the same day in People (or reset password / remove access).
- Review Admin/HR privileges quarterly.
- Monitor Daily Reports and leave approvals for unusual patterns.
- Keep Windows, Linux, Android, and iOS builds current from the official download page / GitHub Releases (1.3.44+).
- Escalate suspected account takeover to info@walfia.ai immediately.

17. Contact & further documents

Resource	Where
Live product	https://scorr.walfia.ai
This security PDF	https://scorr.walfia.ai/downloads/Scorr-Security-Overview.pdf
Full user guide PDF	https://scorr.walfia.ai/downloads/Scorr-Client-Feature-Guide.pdf
App download (all platforms)	https://scorr.walfia.ai/#download-app
Desktop release 1.3.44	https://github.com/usmanHassanzai/HR/releases/tag/desktop-v1.3.44
Windows installer	Scorr-Setup.exe on GitHub Releases
Linux packages	Scorr.deb + Scorr.AppImage on GitHub Releases
Delete-account help	https://scorr.walfia.ai/delete-account
Support	info@walfia.ai

Scorr is built so organizations can run KPIs, attendance, and rewards with clear boundaries: one company, authenticated people, verified MFA, absolute 1-hour sessions, and database-enforced access — on web, Windows, Linux, Android, and iPhone. Share this brief with your IT and leadership teams when evaluating or rolling out Scorr.

© Walfia · https://scorr.walfia.ai · info@walfia.ai

Document generated: October 19, 2026